



Redes, Comunicación y Seguridad

Escuela de Ingeniería

Curso: Sistemas de Información

Profesor: Hernán Cabrera Pichuante

CAPÍTULO 12.1

SEGURIDAD EN SISTEMAS DE INFORMACIÓN

Seguridad informática y seguridad de la información

La Seguridad informática se ocupa de las vulnerabilidades del software (brechas para eventuales ataques externos y/o internos), vela por la Continuidad Operacional (Disponibilidad) de la infraestructura TI frente a siniestros naturales (terremotos, incendios, inundaciones, black-outs) y otros no tan “naturales” como el terrorismo, fraudes y crimen en general, tanto interno como externo a la organización.

Se pueden considerar 4 ámbitos de acción para la Seguridad Informática en una organización:

1. Infraestructura TI (servidores, redes, PCs y otros dispositivos)
2. Sistemas de Información (software, procesos y servicios)
3. Factor humano interno - personal técnico y usuarios
4. Ataques externos (hackers, virus)

Seguridad informática

Es el **conjunto de tecnologías**, procesos, recursos, mecanismos y prácticas, diseñados para proteger la información (electrónica), la plataforma tecnológica y finalmente los activos de una organización, incluida su reputación, contra su uso-apropiación indebida (o no autorizada), o su destrucción o falta de disponibilidad, o falta de integridad-correctitud

Seguridad de la información

IIC2713 Sistemas de I

Profesor Hernán

La seguridad de la información es la **protección de la información** frente a una amplia gama de amenazas, con el fin de asegurar la continuidad del negocio, minimizar sus riesgos, y maximizar el retorno de las inversiones y las oportunidades de negocio.

■ Características de un sistema seguro

Confidencialidad

La información que maneja el sistema debe estar disponible solamente para quienes han sido autorizados para verla o procesarla, por la organización o por las reglas aplicables.

Integridad

La información que el sistema maneja debe ser siempre tan completa, actualizada y correcta, como la organización lo defina o requiera (en base a reglas, restricciones y controles).

Disponibilidad

La información y los sistemas de información están disponibles para los usuarios autorizados cuando la organización lo estima necesario.

Seguridad de la información - ISO 27001/2

La **información** es un **activo** que, como otros activos importantes de la empresa, es esencial para las operaciones de la organización, y en consecuencia necesita ser adecuadamente protegida. Como resultado de la creciente interconectividad de sistemas, la información está en la actualidad, expuesta a un número creciente y a una gran variedad de amenazas y vulnerabilidades.

La seguridad de la información se consigue implantando un conjunto adecuado de **controles**, que incluyen políticas, procesos, procedimientos, estructuras organizativas y funciones de software y de hardware.

IIC2713 Sistemas de I
nformación

Profesor Hernán
Cabrera

Es necesario establecer, implantar, revisar y mejorar estos controles allá donde sea necesario, para asegurar que se cumplen los objetivos específicos de seguridad y de negocio de la organización. Esto debería hacerse de manera conjunta con otros procesos de gestión de negocio.

Seguridad de la información - ISO 27001/2

Toda organización debe definir sus requisitos de seguridad. Estos son, por lo general, obtenidos desde tres fuentes principales:

Evaluación de los riesgos de la organización, esto permite identificar las amenazas sobre los activos de la organización junto a su probabilidad de ocurrencia y su impacto en la operación.

- **Conocimiento de los requisitos legales** que tiene la empresa sobre sus activos. Esto está en leyes, reglamentos, estatutos de la empresa y contratos que tiene tanto como proveedor como prestador de servicios.

La última fuente está dada por la **operación y sus procedimientos** y la necesidad que tienen estos de la información para cumplir con sus objetivos.

-



Riesgos, identificación y mitigaciones: RAID

Risk, Assumptions, Issues, y Dependencias Riesgos, Supuestos, Problemas, Dependencias (RSPD?)

Es muy importante que temprano en un proyecto puedan identificar y hacer seguimiento a cada una de las 4 dimensiones que componen RAID.

Claramente no es factible controlar cada detalle de estos 4 componentes ni menos administrar toda la información que pueda obtener de un análisis y menos tenerlos en la mente todo el tiempo, por eso es bueno mantener una *bitácora* con sus RAID, en la medida que descubran uno nuevo, incorporarlo en la bitácora, priorizarlos y nunca dejar de monitorearlos.

La mejor forma de cazar un tiranosaurio, es cuando éste es aún un huevo.

RAID, uno a uno: Supuestos

Assumptions/Supuestos: Es todo aquello que ustedes suponen, con alta probabilidad, que será verdadero (o que ocurrirá) durante el proyecto o que es requerido para que el proyecto ocurra. Por ejemplo que las personas hablarán sinceramente con ustedes, que los computadores tienen conexión a internet, que se les proporcionará la información requerida (puede haber acuerdo de confidencialidad de por medio)

Si algo que ustedes asumen, no se cumple, eso significa que podrá fallar el proyecto o al menos verse afectado seriamente.

Dejen explícitos sus supuestos y consideraciones. Dejen documentados sus supuestos y comuníquenlos a sus clientes/usuarios NADA, pero NADA, es sentido común o evidente.

Si un supuesto tiene probabilidad de afectar en el futuro al proyecto, se deja como riesgo.



RAID, uno a uno:

Problemas y Dependencias

A diferencia de un riesgo, el **problema** es algo ya materializado y que está afectando directamente al proyecto y por lo tanto requiere de atención y gestión

Dependencias: Tareas o eventos que requieren de otros para comenzar o que son necesarios para que otros eventos ocurran. Las dependencias deben identificarse y controlarse de tal manera de determinar en qué momento pasan a ser ruta crítica y por lo tanto evitar que se transformen en bloqueos del proyecto en general.

RAID, uno a uno: Riesgos

Riesgo: es la probabilidad de ocurrencia de un evento futuro, que impacte en el proyecto, se materialice. Combina en su análisis la probabilidad de aparición y el impacto que este tenga en el proyecto. Con ambas dimensiones se construye la matriz de riesgo

		Probabilidad de ocurrencia				
		Muy baja	Baja	Media	Alta	Muy alta
Impacto en el proyecto	Muy bajo					
	Bajo					
	Moderado					
	Alto					
	Muy alto					

Ataques más comunes

Malware, se define así al software malicioso como spyware, ransomware y virus.

Una vez que el malware entra en función, este puede:

- Bloquear acceso a archivos (ransomware)

- Instalar otro malware o software dañino a sistemas (y hardware)
- Obtener información privada de los sistemas

- Dejar los sistemas inoperables

Phishing, es una práctica que consiste en enviar comunicaciones fraudulentas de manera de engañar al usuario y que éste ingrese información personal importante (claves de banco, números de cuenta corriente, password a sistemas críticos)

Man-in-the-middle es un ataque informático que consiste en intervenir las comunicaciones entre dos sistemas que realizan transacciones

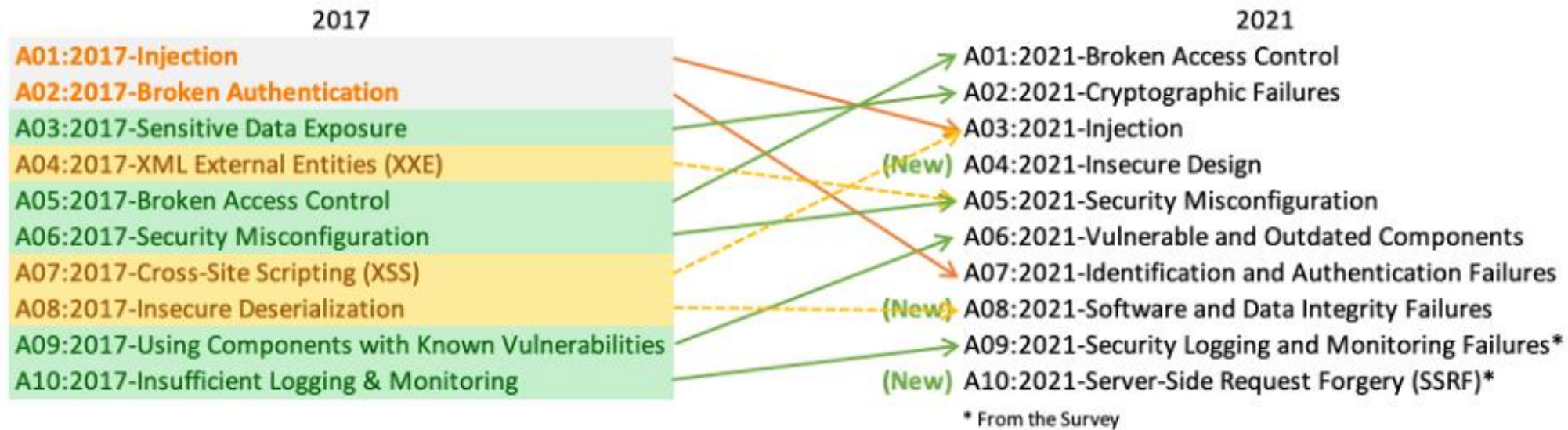
(comunicaciones) y descifrar dicha comunicación (por ejemplo una transacción bancaria)

Puntos comunes de este ataque son redes públicas no seguras de Wifi o malware que esté en alguno de los dos extremos.

OWASP top Ten (Modelo 2021)

Top 10 Web Application Security Risks

There are three new categories, four categories with naming and scoping changes, and some consolidation in the Top 10 for 2021.



<https://owasp.org/www-project-top-ten/>

Ataques más comunes

Denial-of-service (Denegación de servicio o DoS) es un ataque común que inunda de peticiones a servidores o redes para que se saturen tratando de responder y lograr una interrupción de servicio. (piensen este ataque en un servicio de misión crítica como control de operaciones o servicios de inteligencia, etc.)

SQL-injection, es un ataque que se realiza insertando código malicioso entre las comunicaciones de un cliente con un servidor o un servicio con su entrada de datos. Con ello puede acceder a los sistemas y alterarlos.

Aprovechamiento de un zero-day (zero day exploit). Esto ocurre cuando se ha detectado una vulnerabilidad y se anuncia un parche que ha de instalarse. Los atacantes aprovechan ese tiempo para atacar a todas las máquinas esperando que aún no hayan colocado el parche y así, dañar sistemas o robar información clave.



Modelo NIST

<https://csrc.nist.gov/>



<https://blog.silverit.co/entendiendo-el-framework-for-improving-critical-infrastructure-cybersecurity-del-nist/>

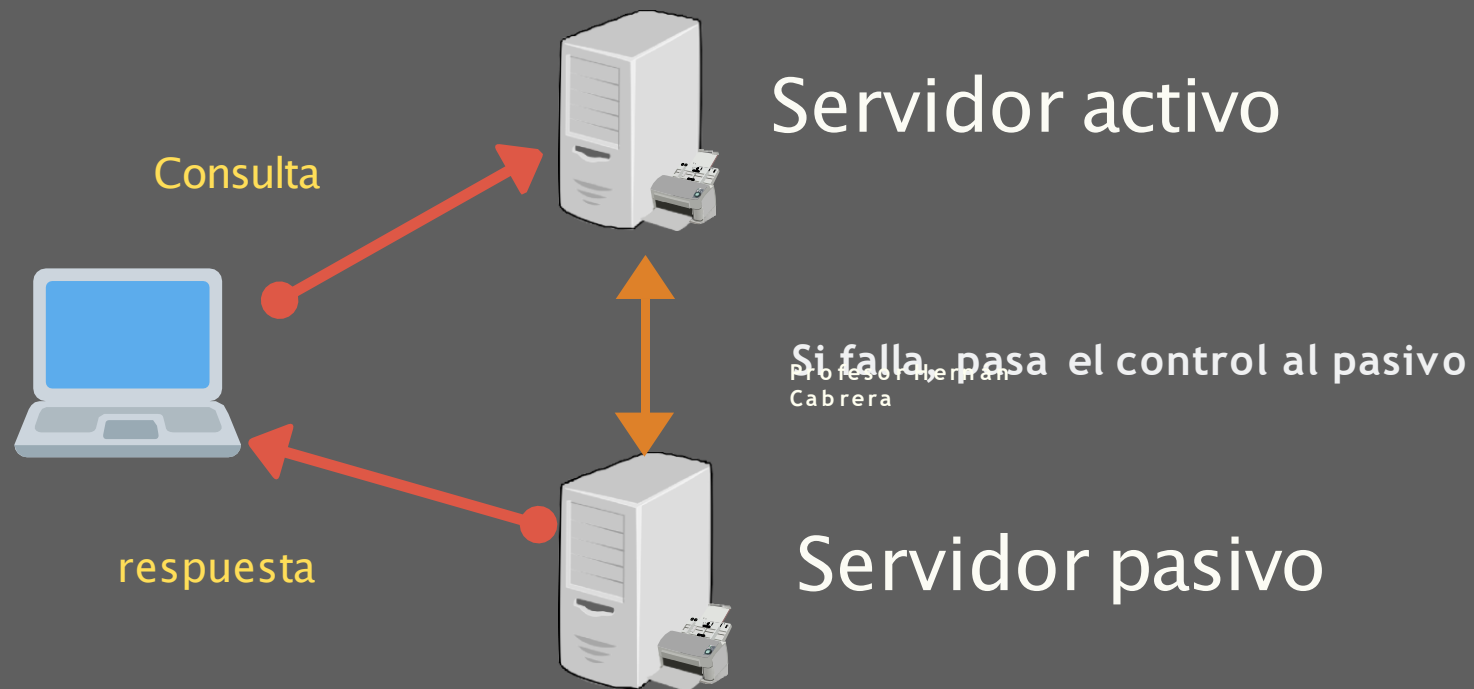
Anexos



Esquemas activo-activo / activo -pasivo

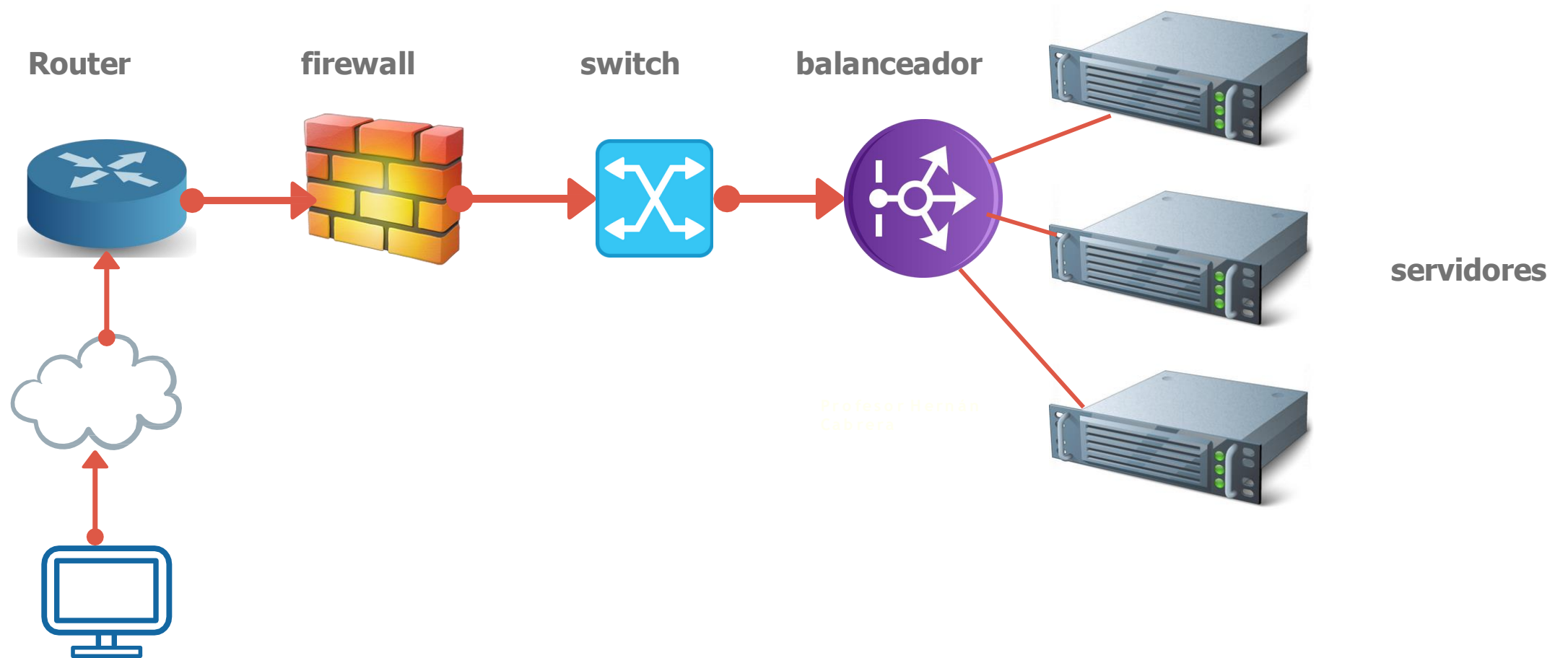


IIC2713 Sistemas de I
nformación

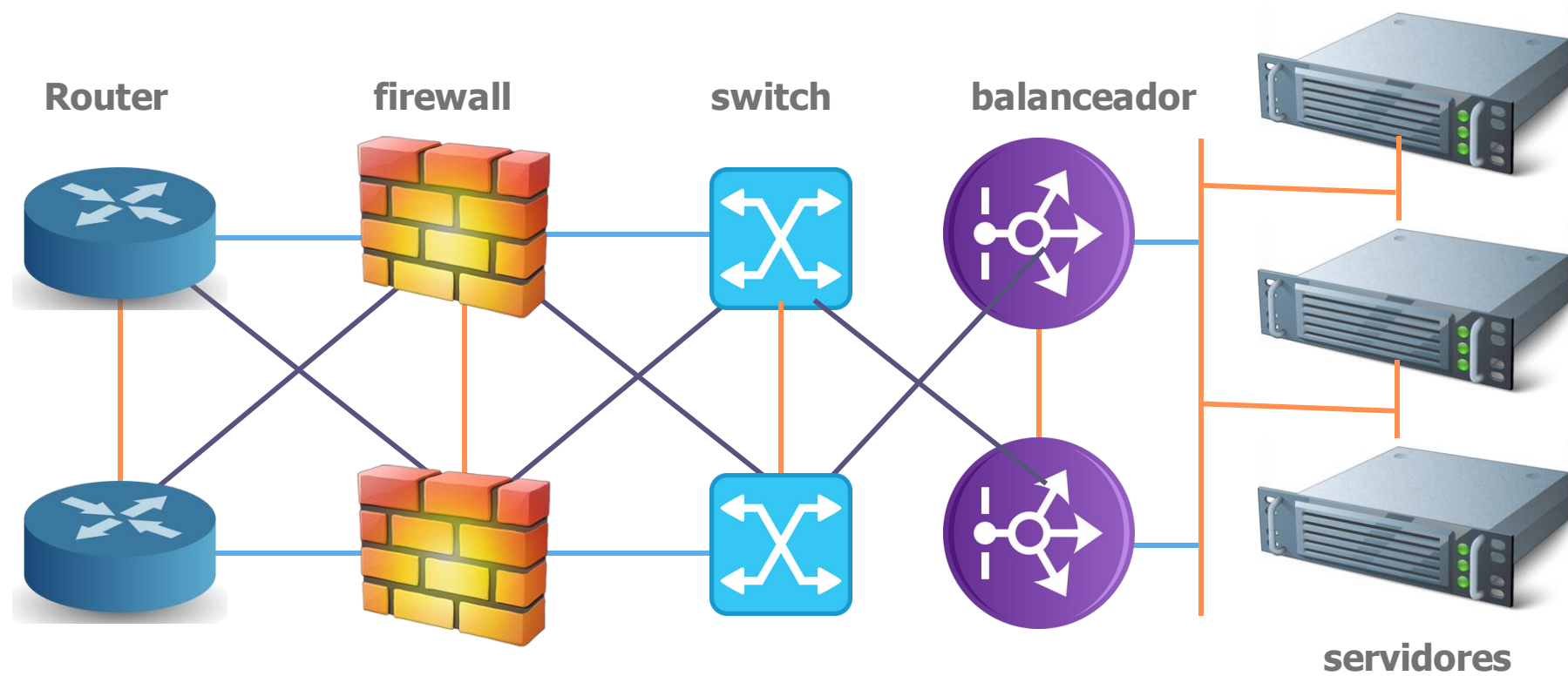


Profesor Hernán
Cabrera

El panorama de un esquema de alta disponibilidad



El panorama de un esquema de alta disponibilidad



Sitio 1

Modelo Conceptual de Riesgos

Riesgo	Objetivo	Probabilidad	Impacto	Mitigación
Que ocurra un terremoto grado 9 o más y la casa se caiga	Mantener casa en pie	Baja	Muy Alto	Construir casa antisísmica
Fallas en mi sistema que no permitan su operación	Mantener los sistemas operativos	Media	Alto	Sistemas replicados, alternativas manuales para sistemas más relevantes
Ataque por empleados descontentos dañen algunos sistemas	Mantener los sistemas operativos	Media	Alto	Control de acceso efectivo y monitoreado División de seguridad TI “más arriba” de la Gerencia Informática

Algunas Tecnologías Clave

 COMPARISON OF 1G TO 5G TECHNOLOGIES					
Technology	1G	2G/2.5G	3G	4G	5G
Deployment	1970/1984	1980/1999	1990/2002	2000/2010	2014/2015
Bandwidth	2kbps	14-64kbps	2mbps	200mbps	>1gbps
Technology	Analog cellular	Digital cellular	Broadbandwidth/ cdma/ip technology	Unified ip & seamless combo of LAN/WAN/WLAN/PAN	4G+WWWW
Service	Mobile telephony	Digital voice, short messaging	Integrated high quality audio, video & data	Dynamic information access, variable devices	Dynamic information access, variable devices with AI capabilities
Multiplexing	FDMA	TDMA/CDMA	CDMA	CDMA	CDMA
Switching	Circuit	Circuit/circuit for access network & air interface	Packet except for air interface	All packet	All packet
Core network	PSTN	PSTN	Packet network	Internet	Internet
Handoff	Horizontal	Horizontal	Horizontal	Horizontal & Vertical	Horizontal & Vertical

